

SECURITY MASTER PLAN

**ICT280-INFORMATION
SECURITY POLICY AND
GOVERNANCE**

**OILTECH
INNOVATIONS**

**ASIS HANG RAI
SYED AHMED SAMEEUDDIN
BIBEK CHAUDHARY THARU**

Document Details

Field	Details
Company Name	OilTech Innovations
Address	OilTech Innovations Tower, Perth 6000, Western Australia
Document Title	Security Master Plan
Unit Code	ICT280
Prepared By	Asis Hang Rai, Syed Ahmed Sameeuddin, Bibek Chaudhary Tharu

Group Declaration

Position	Student Name	Student ID
Chief Executive Officer (CEO)	Asis Hang Rai	35524152
Chief Security Officer (CSO)	Asis Hang Rai	35524152
Director - Back Office	Syed Ahmed Sameeuddin	35570929
Director - Sales & Product	Syed Ahmed Sameeuddin	35570929
Chief Information Officer (CIO)	Bibek Chaudhary Tharu	35581249
Legal Officer	Bibek Chaudhary Tharu	35581249

TABLE OF CONTENTS

1. Introduction.....4

2. Resources at Risk.....7

3. Risk Assessment.....16

4. Risk Management.....20

5. References.....23

6. Appendix — Incident Response Plan.....24

7. Group Declaration Sheet.....40

1. INTRODUCTION

1.1 Company Overview

The company operates from its main office at OilTech Innovations Tower in Perth, Western Australia, and employs a workforce of more than 500 personnel across various departments. The company develops its own software and hardware products, which it uses to serve customers in the oil and gas sector while providing seismic data processing services that assist clients with oil and gas field discovery. The building of OilTech Innovations displays a multi-level structure which includes a Basement area for parking and security operations and loading and unloading spaces and a Ground Level space for reception services and a Level 1 space for building maintenance and training and Research and Development operations and a Level 2 area for General Administration and Human Resources and Finance departments and Sales and Software and Technical Support team operations of Level 3 and Information Technology and server room functions of Level 4 and Data Centre and Seismic Exploration department functions of Level 5. The roof of the building supports air-conditioning units, cooling towers, and water tanks.

1.2 Products and Services

OilTech Innovations has two main product lines and an offering, a service:

SensorDrill is an in-house software and hardware product that is deployed to monitor oil and gas drilling. It is licensed solely to clients for use in their own operations.

MeasureMe is a software and hardware suite owned by MeasureMe that monitors oil and gas pumping. SensorDrill similarly licenses it for independent use.

Shake and Quake is an internally developed seismic data processing system. The product, Shake and Quake, is not licensed to clients, unlike the monitoring products. Rather, the clients submit their raw seismic data, and OilTech Innovations processes, interprets, and formats it, then sends it back to the client in human-readable reports, including graphs, charts, and summaries.

1.3 Market Position

OilTech Innovations now holds about 40 percent of the oil and gas monitoring software market. The main competitor of this company is Another Company Pty Ltd, with an identical market share of 40 percent, and they offer similar monitoring and seismic processing products. The last 20 percent of the market is also spread among the smaller independent software companies that only offer either monitoring software or seismic services, but not both, and cannot be regarded as a significant competitive threat.

1.4 Research and Development

OilTech Innovations conducts two essential research and development initiatives that are significant to its business operations.

Project 1: Real-Time Remote Monitoring (Top Secret): The project includes developing a major system enhancement that will enable SystemDrill and MeasureMe to provide real-time monitoring of drilling and pumping activities via satellite and landline networks. The project delivers a customer-requested feature that no other competitor company has yet successfully implemented. The project will enter closed beta testing and conduct its first field test after one month, with the complete system available six months later. OilTech Innovations expects to gain 10 percent of the market, which corresponds to about \$ 100 million, through its competitive advantage over its main rival. The company classified this project as top secret because it believes its rival lacks the essential capabilities to match OilTech Innovations' upcoming technology, which will provide OilTech Innovations with a minimum 2-year advantage after deployment.

Project 2: Distributed Data Processing: The software enables seismic data processing by distributing tasks across multiple servers, resulting in a 30 percent reduction in standard processing time. The successful outcome of this project will enable increased productivity and faster customer delivery, resulting in annual revenue growth of \$30 million. The project is currently in alpha testing and will take 12 months to reach its final results. OilTech Innovations believes its main competitor is developing a comparable product that will be completed within the next two months. The project requires infrastructure improvements, which include the installation of additional network cables, approximately 10 new servers and workstations, and a new high-speed network switch.

1.5 Organisational Hierarchy

The Chief Executive Officer (CEO) of OilTech Innovations maintains control over all strategic operations of the company. The Chief Security Officer (CSO), the Chief Information Officer (CIO), the Director of Back Office, the Director of Sales and Product, and the Legal Office all report directly to the CEO. The Director of Back Office supervises the Finance Manager, the Human Resources Manager, and the Building and Maintenance Manager. The CIO supervises the Server Team, Network Team, and Desktop Support Team. The Director of Sales and Product supervises the Manager of R&D, the Manager of Software, the Manager of Data Processing, and the Manager of Support and Training. The student team that created this Security Master Plan includes these roles: Asis Hang Rai serves as CEO and CSO, Syed Ahmed Sameeuddin serves as Director of Back Office and Director of Sales and Product, and Bibek Chaudhary Tharu serves as CIO and Legal Officer.

1.6 Purpose of This Security Master Plan

This Security Master Plan (SMP) has been prepared to provide an overall information security governance plan for OilTech Innovations. It records the identification and analysis of threats to the organization's technical, physical, human, and procedural resources. It undertakes a systematic risk assessment and determines appropriate risk management approaches. The SMP is based on internationally recognized standards such as ISO/IEC 27001:2022 and NIST SP 800-53, and is

consistent with the CIA Triad of Confidentiality, Integrity, and Availability as the basis for all security decisions.

The SMP is based on the weekly workshop discussions that will take place in the period (Weeks 18) of ICT280 and complemented by an Incident Response Plan contained in the appendix of this document.

1.7 Key Concepts Established in Week 1

The team used our Week 1 workshop discussions to create essential distinctions that served as the foundation for developing this plan. The two fields of computer security and information security work together because they share common goals, but they maintain their separate functions. Computer security protects computing platforms, networks, and digital systems from unauthorized users who aim to cause system interruptions or system damage. Information security protects all forms of information in digital, physical, and intellectual formats throughout their entire lifecycle.

The presentation explained how leadership and management operate differently. The organization's daily security operations require systematic management, including organizing, planning, and supervising activities that involve implementing policies, allocating resources, and ensuring compliance. The leadership process establishes an organizational security framework through its strategic vision and the development of a security-driven corporate culture. Both elements of security governance must be in place for effective operational control of security measures.

The team identified the following as OilTech Innovations' most critical information assets: proprietary software code (SensorDrill, MeasureMe, Shake, and Quake), hardware designs, R&D project data (particularly Projects 1 and 2), client operational and seismic data, employee personal information, and internal business strategy documentation.

The CIA Triad serves as the fundamental security analysis framework throughout this plan because: Confidentiality protects sensitive information from unauthorized users who should not have access to it; Integrity maintains information accuracy by preventing any alterations; and Availability allows legitimate users to access information and systems whenever they need them.

Lastly, it was ensured that responsibility for information security is shared throughout the organization structure with senior management due to the overall strategic direction and resource allocation, technical staff ensuring controls are in place, all organization staff complying with security policies, and legal and compliance functions being evaluated on the need to comply with regulations.

2. RESOURCES AT RISK

2a. Technical Resources at Risk

2a.1 Information System Components

The technical infrastructure of the OilTech Innovations include: production and development servers (HP ProLiant Gen9 rack-mounted servers with RAID 5), Domain Controller (Windows Server, 2016), File and Print servers, Web server, IBM Blade Centres with proprietary Linux-based operating systems to process seismic data, engineering workstations (mixture of Windows 8.1, Windows 10 Pro, Server 2016, Ubuntu, and Red Hat Enterprise Linux), client desktops (Dell Optiplex 360) and

All client computers are running an image of a standardized OS with antivirus software and the OS firewall turned on. Auto-patches to the OS will be turned off on all client machines to avoid compatibility issues. Automatic patching is also disabled on servers; patches are applied only after compatibility testing on a test server. Symantec Backup Exec is used to back up operations on servers.

2a.2 Technical Threat Analysis by Business Unit

Strategic and R&D Business Unit:

Given the high value of its R&D projects, OilTech Innovations is at serious risk from Advanced Persistent Threats (APTs), which competitors or the state could fund. The confidentiality and integrity of Projects 1 and 2 are directly jeopardized by APT actors' long-term, clandestine campaigns to steal proprietary research data and product designs. Unauthorized disclosure to the rival could completely erode OilTech Innovations' technological advantage, as Project 1 is a top-secret project with the potential to generate a \$100 million market gain.

Attacks using distributed denial-of-service (DDoS) that target simulation environments and R&D services would disrupt the availability of vital development platforms, delaying the release of new products. The data processing IBM Blade Centers are vulnerable to exploitation because their kernels and system applications are infrequently updated, leaving them with unpatched software and instability.

Administrative and Back Office Business Unit:

The biggest technical threat to administrative systems is ransomware, which encrypts and destroys financial and human resources data. The attack surface for ransomware delivered via known vulnerabilities increases when systems are not automatically patched. Attackers may be able to circumvent authentication, obtain private personnel or financial information, or compromise database integrity by exploiting SQL injection flaws in database-connected applications.

Legal and Compliance Business Unit:

Unencrypted backup media data breaches pose a serious risk to confidentiality. Client data is stored by the data processing department on tapes in open racks in the data processing room. Client seismic data, which is commercially sensitive and possibly subject to confidentiality obligations, could be exposed if an unauthorized party accessed these tapes. Exfiltration or alteration of compliance-critical records is another risk associated with insider threats from privileged users.

2a.3 CIA Triad Analysis of Technical Threats

APTs targeting R&D intellectual property, SQL injection attacks that compromise restricted data, and backup media data breaches are the main threats to confidentiality. Ransomware that modifies or destroys data, SQL injection that corrupts database content, and insider record manipulation all pose a threat to integrity. Ransomware that encrypts and locks administrative systems, DDoS attacks that disrupt R&D services, and instability caused by unpatched software vulnerabilities all pose threats to availability.

2a.4 Technical Countermeasures

Technical Controls: Endpoint Detection and Response (EDR) solutions for all workstations and servers; Network Segmentation isolating R&D, administrative, and data processing environments; Data Loss Prevention (DLP) policies monitoring and limiting data transfer; cloud-based DDoS filtering protecting externally accessible services; Web Application Firewalls (WAF) safeguarding the web server; immutable backup systems in place of open-rack tape storage in data processing; and Privileged Access Management (PAM) systems monitoring and auditing the use of administrative accounts.

Operational Controls: Automated incident response playbooks, email security gateways that filter phishing and malicious attachments, parameterized database queries that prevent SQL injection, scheduled backup verification testing, audit logging centralized in a Security Information and Event Management (SIEM) system, encrypted backup media in place of unencrypted tape storage, and threat hunting techniques to identify indicators of compromise proactively

Managerial Controls: Regular vulnerability assessments; mandatory patching schedules with compatibility testing; separation of duties for privileged operations; security awareness training for all employees; and security policies enforcing password management, access control, and acceptable use.

Cross-Cutting Enterprise Controls: Network segmentation to isolate critical systems; Identity and Access Management (IAM) for centralized access governance; SIEM for centralized logging and alerting; security awareness training addressing human-factor vulnerabilities across all business units; and centralized patch management with formal approval cycles.

2b. Physical Resources at Risk

2b.1 Physical Infrastructure Components

The primary and backup data centers on Level 4 and Level 5 that house production servers and storage arrays, server rooms on Level 4 that house HP ProLiant servers and networking equipment, wiring closets on each upper floor that house Cisco switches and routers, R&D laboratories on Level 1 that house important test equipment and prototype hardware related to Projects 1 and 2, and the data processing room on Level 5 that houses IBM Blade Centers and open-rack tape backup media; the basement loading and unloading bay; the security office; and document archives holding legal and compliance records.

2b.2 Physical Threat Analysis by Business Unit

Strategic and R&D Business Unit (Level 1):

The greatest threat to OilTech Innovations is physical intrusion into the R&D laboratories, as the Project 1 prototype hardware and design documentation are located on Level 1. When an intruder has physical access to the R&D lab, they can steal hardware prototypes or copy proprietary design files directly from workstations, bypassing network-based security mechanisms. The passenger lifts operate round the clock, and the stairwell door is open, so once an individual is inside the building, they can reach Level 1 without encountering any physical barriers to access.

Hacking and sneaking by unauthorised parties such as contractors, cleaning staff, or visitors to secured R&D areas is a high risk, as office-level doors are left open during business hours, and the last person to leave is responsible for locking them. This does not make it a strong access control mechanism. Risks to R&D test equipment and prototype hardware exist from environmental factors such as fire, flooding, and power outages. Attacks on social engineering agents of security staff or reception staff may lead to unauthorised access to sensitive floors.

Administrative and Back Office Business Unit (Level 2):

Important financial and human resources systems could be destroyed by fire or water damage to the Level 2 server infrastructure. All administrative operations could be disrupted by extended power outages in the absence of sufficient backup power. Data integrity and hardware availability are at risk due to HVAC failures that cause equipment overheating. A risk to confidentiality is the physical theft of managers' and salespeople's laptops, which hold sensitive operational and financial data. Anyone who reaches Level 4 is free to enter the server room during business hours, as there are no physical access controls.

Legal and Compliance Business Unit (Level 5 / Document Archives):

Confidentiality violations and regulatory infractions may arise from unauthorized access to physical document archives containing client contracts, regulatory filings, and compliance documentation. Data leaks could result from improper disposal of sensitive documents, such as

failing to degauss or shred them. Everyone in the data processing room has access to backup tapes stored on open racks, which poses a risk of theft and exfiltration. Compliance records may become permanently unavailable if a natural disaster strikes the data processing room.

2b.3 CIA Triad Analysis of Physical Threats

Physical intrusion into R&D laboratories, theft of laptops, improper disposal of documents, and leaving tapes in the data processing room on open racks are all threats to confidentiality. Threats to integrity include malicious physical hardware, physical destruction of systems due to environmental conditions surrounding storage media, and unauthorized manipulation of physical access to systems. The threat to availability arises from natural disasters, equipment theft, fires and water damage, HVAC issues, and power outages.

2b.4 Physical security countermeasures.

Access Control Systems Physical access to high security zones: server room, data processing room and R&D laboratory Multi-factor physical access control (card reader and biometric scanner) and mantrap access to the data centre and R&D lab to avoid tailgating; formal visitor management system (need escort during the visit) and card access to relevant floors only; CCTV coverage of all entry access points, lift lobbies and stairways, server room and data processing room; and regular security guards patrols of all floors, especially when the business is closed.

Exceptional Services: Backup HVAC in server room and data processing room with temperature/humidity monitoring; proper fire extinguishers (gases compatible with electronic devices); sensors that detect leaks of water in server rooms; Uninterruptible Power Supply (UPS) in all critical equipment; diesel generators in case of prolonged power interruptions; and frequently testing all the environmental systems.

Asset Protection: Cable locks and secured mounting of all portable devices; hardware tracking of all inventory; caged storage of all backup media rather than racks; an off-site backup facility at a different geographic location; physical audits and penetration testing; and certified shredding and degaussing of all sensitive documents, with media disposal.

Operation Controls: Clean desk policy implemented across all business/units; security awareness training with physical security best practices; visitor/contractor log; incident response to physical security failures/breaches; staff background verification for access to sensitive physical areas; separation of duties for key physical security operations.

Server Room Specific: The server room must be locked, and only authorized IT personnel should be allowed in by using a card and PIN. The existing tradition of leaving the server room unsecured during working hours should be stopped immediately.

Wiring Closet Specification: All wiring closets must be locked at all times on all floors. The existing practice of making them accessible to anyone who wants to should be replaced with a key

management system that allows only authorized IT personnel to use them at their convenience, preventing unauthorized access.

2c. Human Resources at Risk

2c.1 People as the Weakest Link

People, processes, data, hardware, and software make up OilTech Innovations' information systems. People are both the organization's most valuable resource and its biggest security risk. Whether through intentional malicious activity, social engineering, or inadvertent error, human factors are often the main cause of security breaches.

2c.2 Human Threat Analysis by Business Unit

Strategic and R&D Business Unit:

Theft of Project 1 and Project 2 intellectual property is enabled by spear-phishing attacks, a high-priority threat targeting R&D researchers. Attackers create customized emails that harvest credentials or distribute malware. Financially motivated or disgruntled R&D personnel pose an insider threat by disclosing proprietary designs to OilTech Innovations' rival. Social engineering attacks exploit researchers' collaborative nature to trick them into divulging private project information. Given the competitive environment, industrial espionage through relationship cultivation—in which a rival builds rapport with an R&D employee over time to obtain intelligence—is a real threat. The risk profile is increased by shoulder surfing in shared R&D workspaces and a lack of security awareness among technical staff.

Administrative and Back Office Business Unit:

Convenience-driven credential sharing by administrative staff compromises accountability by creating unauthorized access points. Attacks known as Business Email Compromise (BEC) that use fraudulent wire transfer requests to target finance and HR employees could cause large financial losses. Reusing and writing passwords are examples of weak password practices that make you more susceptible to credential theft. Employees are tricked into divulging private payroll or employee information through social engineering. Phishing emails that appear to be internal correspondence often contain malicious attachments or links. One ongoing risk of human error is accidental data exposure from misdirected emails that contain private employee or financial information.

Legal and Compliance Business Unit:

Any unauthorized release of confidential legal documents, client contracts, or regulatory filings by legal employees, intentional or unintentional, is a violation of the confidentiality requirement and regulatory compulsion. Legal personnel, social engineering can be used to obtain information regarding ongoing investigations or compliance. Insider threat. Legal staff who have access to privileged documents can cause information to leak from their possession to generate profit. The

lack of security awareness among legal professionals who might place greater emphasis on legal expertise than on technical security creates a vulnerability. The use of BYOD by law employees who have access to confidential data on their own devices and lack proper data security protocols creates extra risk. There is a risk of an unpleasant disclosure of privileged communications due to human error in their handling.

PeopleRus Human Resource Pty Ltd is also used by Oiltech Innovations to provide temporary and permanent contract staff. The contract workers are accorded access equivalent to that of permanent workers in the same position. However, they may not have undergone the same background checks and security induction as their full-time counterparts, which constitutes a high human security risk. Equally, the cleaning staff of Clean and Mean Pty Ltd work late and have extensive access to the building with limited supervision, which creates the risk of physical reconnaissance or data theft.

2c.3 CIA Triad Analysis of Human Threats

Social engineering, phishing, insider exfiltration, and shoulder surfing are all threats to confidentiality. Insider financial record manipulation, unauthorized changes brought about by social engineering, human error leading to inadvertent data alteration, and inadequate change management procedures all pose a threat to integrity. Insider system sabotage, ransomware installed through social engineering, and human error leading to incorrect configuration or system outages are all threats to availability.

2c.4 Human Security Countermeasures

Security Awareness and Training: All employees must complete annual security awareness training covering data handling, social engineering, phishing, and password management. High-risk jobs in R&D, finance, HR, and law require role-specific training. Phishing simulation campaigns every three months with real-time feedback. All new hires, including PeopleRus contractors, receive a security orientation. Threat updates and policy reminders are included in monthly security awareness communications.

Access Control and Privileged Account Management: Access to the system is restricted to the minimum necessary for each user account, with regular reviews every quarter. Monitoring administrative operations through Privileged Access Management(PAM). Alzation of work concerning major processes. Multi-factor authentication of all remote access and privileged accounts. Tough access provisioning and de-providing policies, such as automatic revocation of access when the contract assignment is terminated.

Personnel Security Controls: Pre-employment background checks of all permanent and contract employees—Non-Disclosure Agreements (NDAs) between all staff and contractors, including staff provided by PeopleRus. Codes of conduct and acceptable use rules are communicated and implied. Well-established exit processes such as immediate account deactivation, NDA reminder, and asset returns.

Technical Controls Supporting Human Security: Email filtering: tools that block outbound data transfers; Data Loss Prevention (DLP) systems: tools for monitoring data transfers bound for external systems; User and Entity Behaviour Analytics (UEBA): tools used to identify unusual user activity; Endpoint Detection and Response (EDR): tools used to manage outbound and inbound data transfers; SIEEM to monitor incoming and outgoing user activity in a centralized manner.

Contractor and Vendor Management: The PeopleRus-supplied contract staff should undergo the same background checks and security inductions as permanent staff before being granted access to the system. Clean and Mean cleaning employees' entry should be controlled or limited to places that do not hold sensitive information resources. Access to Hungerbuster Pty Ltd and Printmaster Pty Ltd will be restricted to agreed service areas, where badges are issued, and every visit is recorded.

2d. Processes and Procedures at Risk

2d.1 The Importance of Security Policies and Procedures

Security policies are high-level governance instructions that stipulate what is to be done and why to protect information assets. Procedures are operational instructions that outline how policies work. They both are necessary: without policies, there are no procedures to provide practical guidance to employees, whereas without policies, there are no procedures to follow and obey.

The security policies and procedures are aimed at creating accountability, maintaining uniform security practices, meeting legal and regulatory mandates, minimizing human error, and providing a basis for enforcement and auditing. Should regulation investigation or legal action occur, then the presence of documented and enforced policies and procedures demonstrates due diligence and due care. Their absence exposes OilTech Innovations to regulatory fines, civil liability, reputational harm, and a failure to demonstrate reasonable security practices.

OilTech Innovations is at a stage where the security policies are poorly documented. Creation of user accounts alerts staff to the need to avoid sharing user accounts and to change passwords regularly, but this is communicated verbally rather than put in writing. Switching off automatic patching is poor practice and should be avoided on all systems. There is no formal policy of data classification. These loopholes pose serious procedural innuendos.

2d.2 Process and Procedure Threat Analysis by Business Unit

Strategic and R&D Business Unit:

There is no official intellectual property (IP) protection policy, indicating that the results of the R&D work, such as Project 1 and Project 2, are not subject to specific regulations governing how these products should be handled, classified, or restricted to certain audiences. Ineffective change management in R&D systems has led to software and configuration changes occurring without

approved documentation or rollback facilities, thereby creating integrity hazards inherent to such systems. There is no policy for data classification, and as a result, sensitive prototype data and research findings are handled without the necessary safeguards. The lack of a clean desk policy and safe disposal is exposing sensitive R&D materials. There is no process for recovering research information when employees depart or change positions.

Administrative, Back Office Business Unit:

The lack of formal policy on access provisioning and de-provisioning procedures has resulted in the access rights of departing staff not being promptly revoked or changed upon a change of position within the organization, leaving persistent access vulnerabilities. There are inconsistencies in the credential hygiene of administrative employees due to undocumented password-handling policies. Formal backup verification procedures are nonexistent, leaving backup integrity unsatisfied and the possibility of undetected information loss. There is no formal incident escalation process, and breaches may not be reported or handled consistently. Weak change management in financial systems poses threats of fraud and integrity lapses.

Legal Business Unit, Compliance Business Unit:

There is a risk that mandatory records will be destroyed, and records that should be destroyed, without any time frame, as there is no formal document retention and disposal policy. There is no documented procedure for notifying of privacy breaches. As a result, OilTech Innovations may not comply with the required reporting deadlines under the relevant privacy laws. Poor legal records and chain-of-custody procedures pose integrity threats to documentation of compliance. The lack of a formal third-party data-sharing policy puts the organization under contractual and regulatory liability when sharing client data with vendors or partners.

2d.3 CIA Triad Analysis of Procedural Threats

Without data classification policies, sensitive information is handled without the proper controls, endangering confidentiality. The lack of change management procedures allows unauthorized or unmonitored system modifications, endangering system integrity. The lack of documented backup verification and disaster recovery procedures puts availability at risk, making the organization unprepared to continue operations following a disruption.

2d.4 Countermeasures for Processes and Procedures

A thorough security policy framework covering data classification and handling, access control and privilege management, incident response and escalation, change management, backup verification, document retention and secure disposal, privacy breach notification, acceptable use, and third-party data sharing must be developed and implemented by OilTech Innovations in accordance with ISO/IEC 27001:2022 and NIST SP 800-53. Formal operational procedures that offer detailed instructions must accompany every policy.

Access must be revoked immediately upon staff departure or role change, and formal access provisioning and deprovisioning procedures must be documented and enforced. The Incident Response Plan outlined in this document must be integrated with a formal incident escalation and reporting procedure. Protocols for data handling and classification must be applied uniformly throughout all business divisions. Document retention schedules and secure disposal procedures, such as certified shredding and digital media sanitization, must be formalized by the Legal and Compliance department. To ensure policies remain up to date with evolving threats and regulatory requirements, regular review cycles must be established. Policy and procedure obligations must be specifically covered in security awareness training.

2d.5 Contingency Planning — BIA, Risk Management, and Disaster Recovery

The process of preparing for interruptions to vital business operations is known as contingency planning. Recovery from incidents becomes haphazard and unreliable in the absence of documented contingency procedures.

Business impact analysis (BIA): OilTech Innovations needs to determine its essential business operations, their interdependencies, and the long-term effects of disruption. For every critical system, this entails setting Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO). Given their revenue and competitive importance, the R&D systems and seismic data processing service are the highest-priority processes

Risk Management (RM): To prioritize remediation efforts, the risk management process assesses the probability and impact of procedural vulnerabilities.

Disaster Recovery (DR): After a significant incident, the DR plan specifies the technical and procedural actions needed to restore operations. DR planning offers an organized approach to organizational resilience when paired with BIA and RM.

2d.6 Legal Implications of Policy and Procedure Gaps

There are serious legal repercussions when security policies and procedures are inadequate. Organizations must take reasonable precautions to protect personal information in accordance with applicable privacy laws, such as the Australian Privacy Act 1988, and notify the regulator and impacted parties of eligible data breaches within specified timeframes. In civil or regulatory proceedings, a failure to maintain documented procedures may be used as proof of negligence. Regulatory bodies may impose financial penalties for noncompliance. The lack of documented policies also compromises the organization's capacity to fulfill employment obligations and exercise due care.

3. RISK ASSESSMENT

3.1 Security Management Best Practices

Proper security management at OilTech Innovations would entail a risk-based approach to implementing, monitoring, and reviewing controls across all business units. The controls should be established according to the accepted models- ISO/IEC 27001:2022 and NIST SP 800-53- and there should be a named owner of each control whose responsibility is to ensure the working of the control.

Hard Copy Workings: A minimum due diligence will include: (1) that each control is documented in writing with a defined scope and purpose; (2) that each control is allocated to a named individual position or role; (3) that all controls are communicated to all employees who they impact; (4) that there is an auditing log of all controls; (5) that controls be reviewed by a designated person on a periodical basis to ensure continued effectiveness.

Legal and regulatory compliance should be checked: This is a major consideration when implementing control elements. Operational feasibility should also be evaluated to ensure that controls do not interfere with important business processes. The cost-benefit analysis has to establish that control costs are commensurate with the asset's value and the probability of threat occurrence. Compatibility with the existing technical infrastructure should be verified.

Measurements and Indicators: The control effectiveness in the case of oiltech innovations will be measured using: count of security incidents before control implementation; internal audit compliance rates; review of access completion rates; Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) to incidents; Percentage compliance with security awareness training.

3.2 Asset Inventory

Information Assets: The R&D research data for Projects 1 and 2, together with the software source code from SensorDrill, MeasureMe, Shake, Quake, client seismic data, processing outputs, client contracts, regulatory filings, financial records, employee personal data, and compliance documentation.

Hardware Assets: The organization operates HP ProLiant Gen9 servers which include Domain Controller and File and Print and Web Server functions and IBM Blade Centres for data processing and Dell Optiplex 360 desktops and Dell laptops which managerial and sales and IT staff use and Dell Precision desktops and laptops which R&D and software and support teams use and Cisco 3750E core switches and Cisco 2960 access switches which provide one switch for each floor and Cisco 3845 ISR routers and Cisco 1262AG wireless access points and Cisco 7941G IP phones and HP 1/8 G2 Tape Autoloaders which serve as backup for server and data processing and physical security equipment.

Software Assets: The organization operates Windows Server 2016 which functions as Domain Controller and File and Print and Web Server and customized Linux OS which operates on IBM

Blade Centres and Windows 10 Pro which runs on client desktops and laptops and Windows 8.1 which operates on some R&D workstations and Ubuntu and Red Hat Enterprise Linux which the R&D department uses and Symantec Backup Exec and antivirus and firewall software and SensorDrill and MeasureMe and Shake and Quake proprietary platforms and virtual machine environments which exist in R&D.

Personnel: The organization includes a workforce consisting of the CEO, CSO, CIO, Directors, Managers, R&D staff, IT staff, legal and compliance officers, administrative and finance staff, support and training staff, and contract staff from PeopleRus and contractors from Clean and Mean, Computex, Printmaster, and Hungerbuster.

3.3 Asset Classification and Valuation

There are four sensitivity levels on which assets are to be divided:

Constricted: R and D intellectual property (data on Project 1 and Project 2, prototype hardware and designs); the Shake and Quake software source code; customer seismic data. The assets will have the greatest business, replacement, and regulatory value. A single project 1 data leak may destroy a 100-million-dollar market prospect.

Joan: Financial records; client contracts; employee personal data; source code of SensorDrill and MeasureMe; legal and compliance documents.

Internal: Standard working documentation; Hr policy records; non-sensitive internal correspondence; Hardware inventory records.

Public: Marketing documents; published datasheets about products; published information about the company.

Controls are allocated in descending order of sensitivity, with the strictest level applied to Restricted assets.

3.4 Asset Ranking (Most Critical to Least Critical)

Following the TVA methodology, OilTech Innovations' critical IT resources are ranked as follows:

Rank	Resource	Justification
V-1	Software Program and R&D Patents	Directly tied to competitive advantage and \$100M+ revenue potential
V-3	Engineering Intellectual Property (Project 1 & 2 data)	Top-secret R&D; loss would eliminate technology lead
V-5	Operations and Database Servers	Support all business operations and client data processing
V-2	Patented Software Operations Processes	Underpins SensorDrill, MeasureMe, and Shake and Quake
V-6	Skilled Labour Force	Unique expertise; difficult to replace

V-4	SCM System	Supports software delivery and vendor management
-----	------------	--

3.5 Vulnerability Assessment

R&D Data Systems: There is a risk of unauthorized access due to the lack of a formal data classification and access control policy. Virtual machine environments and mixed OS platforms expand the attack surface.

Administrative Systems: Susceptible to credential -based assaults through undocumented password controls and the unavailability of MFA. Vulnerability to insider threat caused by the absence of access provision controls.

Legal Records: Prone to inappropriate retention and disposal since there is no document retention policy. Chain storage of information in a data processing room is physically available and credible; creation of custody gaps causes integrity vulnerability.

Backup Systems: it is the Open-rack tapeng a risk of theft or unauthorized access. No procedures for backup testing are recorded.

Network Infrastructure: Wiring closets per floor are not locked down, leaving Cisco switches and routers in positions where they can be physically tampered with. The ISP cable conduit feeds into the wiring closet on the ground level, which is a single point of failure for all internet connectivity.

Patching: Patching is not automatically turned on in all client computers and servers. Although patches are tested before deployment, the lack of a formal patching schedule means vulnerabilities can remain unpatched for a long time.

3.6 Threat-Vulnerability Assessment (TVA) Worksheet

Current State TVA Matrix

The table below maps OilTech Innovations' prioritized IT resources to the most likely threat agents, identifies the existing protection mechanisms, and outlines the remaining vulnerabilities. The existing protection measures include: S1- Firewalls, S2-IDS/IPS, S3-Anti-Virus Software, S4- Double Authentication, S5- Encryption, S6- SETA (Security Education, Training and Awareness) Policies.

Ranked Threat Agents (Most to Least Probable)	V-1: SW Program Patents	V-3: Engineering IP	V-5: Operations & DB Servers	V-2: Patented SW Ops Process	V-6: Skilled Labour Force	V-4: SCM System
1. Theft of Intellectual Property	S1, S5, S6	S1, S4	S1, S2, S3, S5	S1, S4, S5, S6	S6	S1, S2, S3, S4, S5, S6

2. Sabotage to Programs, IP, Ops, SCM	X	X	X	S1, S2, S3, S4, S5, S6	N/A	S1, S2, S3, S4, S5, S6
3. Loss of SCM Vendors	N/A	N/A	X	S4	N/A	S1, S2, S3, S4, S5, S6
4. Password Cracking	X	S1, S4	S1, S2, S3, S4	S1, S2, S4, S5	S6	S1, S2, S3, S4, S5, S6
5. Social Engineering of Employees	X	X	X	X	X	S1, S2, S3, S4, S5, S6
6. DoS Attack / Website Outage	N/A	N/A	S1, S2, S3, S4, S5	S4, S5	N/A	S1, S2, S3, S4, S5, S6

(X = No adequate current safeguard in place; N/A = Threat not applicable to this resource)

Proposed TVA Matrix

The following table presents OilTech Innovations' proposed state, adding three new safeguards: S7 — Non-Disclosure Agreements; S8 — Vendor HoneyPots; S9 — Redundant Database. A seventh threat agent — Ransomware and Data Encryption — is also added given its elevated prevalence.

Ranked Threat Agents	V-1: SW Program Patents	V-3: Engineering IP	V-5: Operations & DB Servers	V-2: Patented SW Ops Process	V-6: Skilled Labour Force	V-4: SCM System
1.External & Internal Theft of IP	S1, S2, S4, S5, S6	S1, S2, S4, S5, S8, S9	S1, S2, S3, S5, S8, S9	S1, S4, S5, S6, S9	S6	S4, S5, S9
2.Sabotage to Programs, IP, Ops, SCM	S1, S2, S4, S5, S6, S9	S1, S2, S4, S5, S6, S9	S1, S2, S4, S5	S1, S2, S3, S4, S5, S6	N/A	S4, S5, S9
3.Loss of SCM Vendors	N/A	N/A	S2, S5, S7	S4	N/A	S7, S9
4.Password Cracking of IS	S1, S2, S4, S5, S6, S9	S1, S4, S8, S9	S1, S2, S4, S5, S9	S1, S2, S4, S5	S6	S5, S9
5.Social Engineering of Employees	S2, S4, S5, S6, S7, S9	S2, S4, S5, S6, S7, S9	S2, S4, S5	S2, S4, S5	N/A	S4, S6, S7
6.DoS Attack / Website Outage	N/A	N/A	S2, S3, S4, S5, S8, S9	S4, S5, S8, S9	S2, S4, S5	S6, S8, S9

7. Ransomware & Data Encryption	S2, S3, S4, S5, S8, S9	S2, S3, S4, S5, S8, S9	S2, S3, S4, S5, S8, S9	S2, S3, S4, S5, S8, S9	S6, S7, S9	S4, S5, S8, S9
---------------------------------	------------------------	------------------------	------------------------	------------------------	------------	----------------

Proposed IT Safeguards (Unranked): S1 Firewalls; S2 IDS/IPS; S3 Anti-Virus SW; S4 Double Authentication; S5 Encryption; S6 Enhanced SETA Policies; S7 Non-Disclosure Agreements; S8 Vendor HoneyPots; S9 Redundant Database

4. RISK MANAGEMENT

4.1 Risk Control Strategy Framework

OilTech Innovations uses four risk control measures to address the risks listed in the TVA worksheet: Avoidance (getting rid of the vulnerability), Transference (sending the risk to a third party), Mitigation (reducing the probability or the impact of the threat), and Acceptance (recognizing an uncontrolled risk whose cost of control is greater than the expected loss). In accordance with ISO/IEC 27001:2022 and NIST SP 800-30, the selection of the strategy is informed by a cost-benefit analysis (CBA) and a feasibility assessment. It is guided by a risk-scoring methodology (likelihood × impact).

4.2 Risk Strategy Selection by Business Unit

R&D Business Unit

Risk: Unauthorised Access to R&D Research Data — Strategy: AVOIDANCE

The main vulnerability allowing unauthorized access to Project 1 and Project 2 data, according to the Week 7 vulnerability assessment, is the lack of a formal data classification policy and insufficient role-based access control. Avoidance is chosen because technical and policy controls can eradicate the vulnerability at its source. Deploying a data classification framework in line with ISO/IEC 27001, implementing Role-Based Access Control (RBAC), restricting access to authorized personnel only, removing superfluous access privileges, and providing required training on data-handling responsibilities are all part of the implementation process. In comparison to the \$100 million market value of Project 1 data, CBA confirms that implementation costs are insignificant.

Risk: IP Loss Following a Successful Breach — Strategy: MITIGATION

An encrypted, off-site disaster recovery (DR) backup of all R&D data, a tested incident response (IR) plan that facilitates quick identification and containment, and routine DR testing that guarantees operational readiness are ways to mitigate the impact of a breach despite avoidance controls. This tactic minimizes the window of competitive exposure and directly shortens recovery time.

*Administrative and Back Office Business Unit***Risk: Credential Compromise of Administrative Systems — Strategy: MITIGATION**

Mandatory MFA reduces the likelihood of successful credential-based attacks across all administrative access points, and a formally documented, enforced password policy further reduces the likelihood of such attacks. In the event of an incident, these controls also enhance MTBD/MTTR metrics. Given the frequency and impact of credential-based attacks on administrative systems that hold payroll, financial records, and HR data, implementation costs are reasonable and commensurate with the risk.

Risk: Third-Party Vendor Breach — Strategy: TRANSFERENCE

The security posture of its vendors (PeopleRus, Computex, Printmaster, Clean and Mean, Hungerbuster) is not directly under OilTech Innovations' control. Data processing agreements with liability and breach notification clauses, updated vendor contracts with minimal security requirements, and cyber liability insurance that covers residual financial exposure from external breaches are all used to choose transfers. This tactic encourages vendors to uphold sufficient security standards while shifting financial and legal exposure.

*Legal and Compliance Business Unit***Risk: Improper Document Retention and Disposal — Strategy: AVOIDANCE**

By formalizing a documented retention schedule with precise deadlines and secure destruction requirements (certified shredding for physical documents, degaussing or destruction for magnetic media), the procedural gap found in Week 6—the lack of a document retention and disposal policy—can be closed. Enforcement is aided by mandatory training on document handling regulations. Instead of just controlling its effects, this avoidance tactic gets rid of the underlying vulnerability.

Risk: Minor Procedural Compliance Audit Failures — Strategy: ACCEPTANCE

The cost of fully automated compliance monitoring (acquisition, configuration, and continuous maintenance) was found disproportionate to the probable financial impact of minor procedural audit failures, as determined by a comprehensive CBA. To provide a reasonable level of assurance without incurring unnecessary costs, acceptance is formally documented, and a manual periodic review process is established. This choice is recorded and will be examined once a year.

4.3 Resource Prioritisation and Cost-Benefit Analysis

Since OilTech Innovations' resources are limited, the likelihood $\times$ impact approach was used to rank control investments. The three topmost priority investments include:

1. **RBAC and data classification of the R&D assets** -Project 1 and Project 2 value High impact, highly likely to be targeted attack. The cost of control is not high compared to the loss incurred.
2. **MFA and password policy on administrative systems** -The probability of a credential-based attack is high, and the attack has a high impact on business operations and financial databases. Control cost is equivalent and fair.
3. **Legal and Compliance Formalization of document retention and disposal** - Moderate risk of regulatory audit failure, high legal and financial consequences of non-compliance. The cost of control is minimal (policy development and training).

All of these controls were determined to be cost-effective, and the value of the assets and the probability of exploitation were significantly greater than the costs of implementation and maintenance.

4.4 Residual Risk and Risk Appetite

OilTech Innovations understands that no security program can eliminate risk. The risk that remains after controls are implemented is known as residual risk, and it must align with the organization's risk tolerance. If control costs are clearly out of proportion to the expected loss, the organization will accept low-rated residual risks as long as they are formally documented and regularly reviewed. The program's objective is to align residual risk with the organization's risk appetite under ongoing governance rather than to eliminate risk.

4.5 Assumptions

The following presumptions form the basis of this risk management analysis: (1) senior management pledges to allocate resources in accordance with the risk levels identified; (2) OilTech Innovations is subject to applicable data protection and privacy legislation, including the Australian Privacy Act 1988; (3) the asset inventory created in Week 7 accurately reflects the current information asset environment; (4) management will support control implementation through appropriate change management communication; and (5) employees will cooperate with training and control implementation.

5. REFERENCES

1. Address, J. (2014). *The basics of information security: Understanding the fundamentals of InfoSec in theory and practice* (2nd ed.). Syngress.
2. Fennelly, L. J., & Perry, M. A. (2020). *The handbook for school safety and security: Best practices and procedures* (2nd ed.). Butterworth-Heinemann.
3. Garcia, M. L. (2023). *The design and evaluation of physical protection systems* (3rd ed.). Butterworth-Heinemann.
4. Hadnagy, C. (2018). *Social engineering: The science of human hacking* (2nd ed.). Wiley.
5. International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. <https://www.iso.org/standard/27001>
6. Mitnick, K. D., & Simon, W. L. (2002). *The art of deception: Controlling the human element of security*. Wiley.
7. Murdoch University. (2025). *IT security policy*. <https://www.murdoch.edu.au/admin/policies/itsecurity/>
8. National Institute of Standards and Technology. (2010). *NIST Special Publication 800-34 Rev. 1: Contingency planning guide for federal information systems*. <https://doi.org/10.6028/NIST.SP.800-34r1>
9. National Institute of Standards and Technology. (2012). *NIST Special Publication 800-30 Rev. 1: Guide for conducting risk assessments*. <https://doi.org/10.6028/NIST.SP.800-30r1>
10. National Institute of Standards and Technology. (2020). *NIST Special Publication 800-53 Rev. 5: Security and privacy controls for information systems and organizations*. <https://doi.org/10.6028/NIST.SP.800-53r5>
11. Pfleeger, C. P., & Pfleeger, S. L. (2023). *Security in computing* (6th ed.). Prentice Hall.
12. Stallings, W., & Brown, L. (2023). *Computer security: Principles and practice* (5th ed.). Pearson Education.
13. Von Solms, R., & Von Solms, J. (2018). Information security governance: A model based on the Direct-Control Cycle. *Computers & Security*, 77, 735–745. <https://doi.org/10.1016/j.cose.2018.01.013>
14. Whitman, M. E., & Mattord, H. J. (2019). *Management of information security* (6th ed.). Cengage Learning.
15. Whitman, M. E., & Mattord, H. J. (2021). *Management of information security* (7th ed.). Cengage Learning.

6. APPENDIX — INCIDENT RESPONSE PLAN

OilTech Innovations

Cyber Security Incident Response Plan

Based on the Delinea Privileged Account Incident Response Plan Template

Ownership and Approval

Field	Details
Policy Owner and Title	Asis Hang Rai - Chief Security Officer (CSO)
Phone	+61 8 XXXX XXXX
Email	a.raai@oiltech-innovations.com.au
Date	28/03/2026
Approved By	Asis Hang Rai - Chief Executive Officer (CEO)
Date	28/03/2026

Revision History

Version	Description	Revision Date	Review Date	Reviewer
1.0	Initial Version	04/02/2026	28/03/2026	Asis Hang Rai, Syed Ahmed Sameeuddin, Bibek Chaudhary Tharu

Compliance Requirements

Compliance Rule	Description
Australian Privacy Act 1988	Mandates that OilTech Innovations notify the OAIC and impacted parties of eligible data breaches under the Notifiable Data Breaches (NDB) scheme and take reasonable precautions to protect personal information.
ISO/IEC 27001:2022	OilTech Innovations' security governance is based on an international standard for information security management systems.
NIST SP 800-53 Rev. 5	Offers the framework for security and privacy controls used in this IRP.
Australian Corporations Act 2001	Imposes requirements on OilTech Innovations to disclose breaches and maintain records.

Executive Summary

To ensure the confidence of our employees, customers, and partners, and to comply with regulatory requirements, OilTech Innovations will do whatever can be reasonably done in the event of a cyber-attack to protect confidential information and systems. The better equipped we are to act in the event of a possible cyberattack, the quicker we can localize and eliminate the threat and minimize its impact on the business.

This Incident Response Plan (IRP) is intended to equip OilTech Innovations to respond quickly and effectively to cyber threats and to continue operating as usual. Activities within this plan include protecting privileged accounts that provide access to important systems, such as our Domain Controller, R&D development environments, seismic data processing servers, and the SensorDrill, MeasureMe, Shake, and Quake platforms. They are service, application, and root accounts; network and administrator accounts; and local domain accounts.

Most participants in the organization's response to the incident, including the IT and the security teams, legal, technical support, human resources, corporate communications, and business operations, are all effective in responding to the incident at OilTech Innovations. Every employee must read and understand their responsibilities under this plan.

The plan will be revised and reviewed on an annual basis, and after any major incident, to include any modifications to the organization, new technology, and new compliance requirements. During implementation, regular testing will be used to ensure team members are well-trained to participate in effective incident response.

Immediate Mitigation Actions

The IT security team at OilTech Innovations must take the following steps right away, regardless of how a security incident or breach is found:

- Create new Domain Administrator accounts with new credentials and disable the old ones.
- Change every system's local and domain credentials.
- Apply all security patches pertinent to the breach and shut down the OS environment.
- Examine the activity of newly created accounts from the incident date.
- Examine and keep an eye out for questionable activity on all privileged accounts.
- On the Domain Controller, reset Kerberos tickets.

Roles, Responsibilities, and Contact Information

INFORMATION SECURITY

Role	Responsibility	Contact Details
Chief Security Officer (CSO) / Incident Commander	Oversees all incident response operations strategically; establishes risk-ranking standards for response prioritization; approves reporting of incident details and timing; primary point of contact for the Board and CEO	Asis Hang Rai — +61 8 XXXX XXXX — a.raai@oiltech-innovations.com.au
Incident Response Team Lead	Oversees the entire incident response process for all teams; maintains incident catalog and IRP documentation; verifies and assesses scope of incidents	Asis Hang Rai (CSO) + CIO Network/Server Teams
Chief Information Officer (CIO) / Technical Response Lead	Oversees technical response and investigation; manages Desktop Support Team, Network Team, and Server Team	Bibek Chaudhary Tharu — +61 8 XXXX XXXX — b.tharu@oiltech-innovations.com.au
Identity and Access Team	Manages RBAC, enterprise password protection, and privileged accounts; monitors and reports privileged account usage; detects signs of compromise; updates privileges to contain breaches	CIO's Network Team
IT Operations and Support	Controls internal user access; manages software and hardware updates and patching to prevent attacks	CIO's Server Team and Desktop Support Team

COMPLIANCE

Role	Responsibility	Contact Details
Legal Officer	Verifies the requirements for notifying the public, clients, and employees; communicates with the police; guarantees the legal right to monitor privileged accounts.	Bibek Chaudhary Tharu - b.tharu@oiltech-innovations.com.au
Audit and Compliance	Interacts with OAIC and other regulatory agencies; oversees the NDB scheme's mandatory reporting requirements.	Legal Office, OilTech Innovations
Human Resources Manager	Organizes internal staff communications about personal data breaches; answers questions from employees.	Director – Back Office: Syed Ahmed Sameeuddin

COMMUNICATIONS

Role	Responsibility	Contact Details
Director – Sales and Product / External Communications Lead	Interacts with partners, clients, and the media; oversees all media interviews and external communications; keeps crisis communication templates up to date.	Syed Ahmed Sameeuddin — s.sameeuddin@oiltech-innovations.com.au
Technical Support Lead (Internal)	During a breach, staff members receive security alerts and technical assistance, including necessary password changes and system updates.	CIO's Desktop Support Team
Technical Partners (Big Lake ISP, Computex)	Oversees security measures to prevent an attack from spreading to other systems; collaborates on risk management with OilTech Innovations' IRT.	Big Lake ISP Account Manager — [contact details on file]

Threat Classification

OilTech Innovations prioritizes the necessary level of response by classifying incidents using the CIA Triad framework:

Confidentiality: Unauthorized system access incidents, such as the compromise of privileged accounts. The potential impact increases with data confidentiality (e.g., Project 1 R&D data, client seismic data) and system criticality.

Integrity: Data manipulation incidents, such as the use of a privileged account to alter or corrupt data. The potential impact increases with the sensitivity of the data.

Availability: Events that affect service availability, such as ransomware or DDoS attacks, as well as the use of privileged accounts for unauthorized modifications. The potential impact increases with the service's importance to OilTech Innovations' operations (e.g., seismic data processing, R&D environments).

Sample Cyber Incident	CIA Category	Privileged Account Breach	Business Impact	Risk Level
Employee shares non-sensitive information with an unauthorized third party	C	No	Low	Low
Malware leverages local credentials, and adware appears on the workstation	C, I	Yes	Low	Medium
The attacker uses the pass-the-hash technique to access multiple databases and root accounts.	C	Yes	High	High
Attacker uses privileged access to encrypt R&D data and demand ransom	C, I, A	Yes	High	High
The attacker gains physical access to the R&D lab and copies the Project 1 prototype data.	C, I	No (physical)	Critical	High

OilTech Innovations Compliance and Legal Obligations

OilTech Innovations is obligated by the Australian Privacy Act 1988 and the Notifiable Data Breaches (NDB) scheme to promptly notify the Office of the Australian Information Commissioner (OAIC) and impacted parties of any eligible data breach that could cause significant harm. Breach of client data (seismic processing reports, contracts) and employee personal information is covered by this notification requirement.

To ensure it can meet notification deadlines and provide impacted parties with meaningful responses, OilTech Innovations must maintain documented procedures. There may be civil penalties for failing to notify, in violation of the Privacy Act.

ACTIONS TAKEN DURING INCIDENT RESPONSE

Incident Scenario: Ransomware Attack via Spear Phishing - R&D Department

Incident Description: An R&D researcher at OilTech Innovations received a spear phishing email on Tuesday, February 10, 2026, requesting that they update their VPN credentials via a link. The email appeared to be from the company's IT department. The researcher unintentionally downloaded a malicious payload after clicking the link and entering their login information into a fake login page. After gaining access to the R&D network segment using the credentials they had stolen, the attacker deployed ransomware to begin encrypting files on the R&D file server, including folders containing prototype test data and Project 1 design documents. When encryption activity was detected at 11:47 PM, the SIEM system issued an alert. At 11:55 PM, the incident was reported to the CSO.

Phase	Action	Team Member / System	Day / Time / Action Taken
Incident Discovery and Confirmation	Unusual file-encryption activity on the R&D file server triggered an alert from the SIEM system. The alert was acknowledged by the on-call Network Team and forwarded to the CSO.	SIEM System / Network Team On-Call	Tuesday 10/02/2026 — 11:47 PM. Alert generated. Escalated at 11:55 PM.
Incident Discovery and Confirmation	Logs of audits were examined. Logs revealed that at 11:31 PM, a mass file-encryption process was initiated using the	CIO — Bibek Chaudhary Tharu / Network Team	Wednesday 11/02/2026 — 12:15 AM. Logs reviewed and suspicious activity confirmed.

	compromised researcher's credentials. An unusual login from an external IP address that was not previously connected to the researcher was identified in the login records.		
Incident Discovery and Confirmation	Based on competitive intelligence or financial gain (ransom), it was determined that the attacker was most likely an external threat actor targeting R&D intellectual property. Actions typical of an operator of ransomware-as-a-service (RaaS).	CSO — Asis Hang Rai	11/02/2026 — 12:30 AM. Attacker profile assessed.
Incident Discovery and Confirmation	The spear-phishing email sent to the researcher's OilTech Innovations email account at 4:43 PM on October 02, 2026, was identified as the access point. The current email filter was circumvented by the email. When the researcher visited the fake credential page, the malicious payload was executed.	CIO / Desktop Support Team	11/02/2026 — 1:00 AM. Phishing email identified in the mail server logs. Endpoint confirmed as the researcher's workstation on Level 1.
Incident Discovery and Confirmation	Phishing email delivery at 16:43, credential harvest at 16:51, external login at 23:31, ransomware deployment at 23:31, SIEM alert at 23:47, and CSO notification at 23:55 were all documented in an incident timeline	CSO / CIO	11/02/2026 — 1:15 AM. Timeline documented.

	created and recorded in the incident management repository.		
Incident Discovery and Confirmation	Threat intelligence databases were consulted for applications, IP address ranges, file hashes, processes, and executable names. A known RaaS variant was found to be consistent with the ransomware strain. IoCs (indicators of compromise) were recorded.	CIO / Network Team	11/02/2026 — 1:30 AM. IoCs documented and shared with the IR team.
Incident Discovery and Confirmation	About 40% of the R&D file server content, including Project 1 design documentation folders, was encrypted. Since Project 1 is hosted on a different development server with different credentials, the source code repository was unaffected. There was no compromise of privileged domain administrator accounts.	CIO / Server Team	11/02/2026 — 2:00 AM. Extent of damage confirmed.
Incident Discovery and Confirmation	The list of information assets was examined. R&D test data (Confidential) and Project 1 design documents (Restricted classification) were identified as encrypted assets. Unencrypted asset integrity was verified from the most recent backup (10/02/2026 at 6:00 AM).	CSO / Legal Officer — Bibek Chaudhary Tharu	11/02/2026 — 2:15 AM. Asset integrity documented.

Incident Discovery and Confirmation	Email was avoided as a precaution until it was confirmed that the mail server was unaffected; all employees were informed via SMS. R&D personnel were told not to try to access the file server and to log off all systems.	Director – Back Office — Syed Ahmed Sameeuddin / HR Manager	11/02/2026 — 3:00 AM. All staff notified.
Incident Discovery and Confirmation	Threat intelligence tools are used to analyze IoCs. A known actor group was matched to the ransomware variant. The IR team received the advisory.	CIO / Network Team	11/02/2026 — 3:30 AM. Intelligence report produced.
Incident Discovery and Confirmation	In accordance with compliance requirements allowing a reasonable investigation period before public notification under the NDB scheme, the decision was made to withhold external communications until the breach was contained.	CSO / Legal Officer	11/02/2026 — 3:45 AM. Communication is held authorised.
Containment and Continuity	To avoid using potentially compromised regular domain accounts for investigation and remediation, temporary privileged accounts were created for the incident response and security teams.	CIO / Network Team	11/02/2026 — 2:00 AM. Temporary IR accounts created.
Containment and Continuity	Both the impacted R&D file server and the compromised researcher's workstation were cut off from the	Server Team / Network Team	11/02/2026 — 2:10 AM. Isolation complete. Forensic images secured.

	network. Before taking any corrective action, forensic photos of both systems were taken.		
Containment and Continuity	All remaining active accounts were subject to MFA, with administrative and R&D accounts receiving special attention. Before gaining access to any system, all employees must re-authenticate using MFA.	CIO / Identity and Access Team	11/02/2026 — 4:00 AM. MFA is enforced organisation-wide.
Containment and Continuity	Every domain user, service account, application account, and network account password were changed. Kerberos tickets were reissued after being deemed invalid. The Domain Administrator account was changed and disabled.	CIO / Server Team	11/02/2026 — 4:30 AM. All credentials have been rotated.
Containment and Continuity	Controls over application security were strengthened. All endpoints were prevented from executing unsigned executables. Every link in incoming emails was sandboxed for analysis, and the sensitivity of email filtering was raised.	CIO / Desktop Support Team	11/02/2026 — 5:00 AM. Controls tightened.
Containment and Continuity	The R&D file server was shut down. Every other server was still in use. Administrative, legal, and data processing operations	Server Team	11/02/2026 — 5:00 AM. R&D file server offline. Other systems are operational.

	all maintained business continuity.		
Containment and Continuity	Every employee received an SMS about the containment of the breach. Employees were told to report any suspicious emails right away and to be on the lookout for phishing attempts.	Director – Back Office — Syed Ahmed Sameeuddin	11/02/2026 — 7:00 AM. Staff notification issued.
Containment and Continuity	DLP logs and network traffic analysis are used in data exfiltration analysis. The ransomware seemed to be an encryption-only variant without the ability to exfiltrate data, as no evidence of data exfiltration was found.	CIO / Network Team	11/02/2026 — 8:00 AM. No exfiltration detected. Documented.
Containment and Continuity	In accordance with the NDB scheme timeline allowances, external notification is pending confirmation of eradication. Since the investigation was ongoing and no significant harm had yet been proven, the legal officer confirmed that there was no immediate notification obligation.	Legal Officer — Bibek Chaudhary Tharu	11/02/2026 — 8:30 AM. Legal review completed.
Eradication	Every firewall rule was examined. The IoC report blocked outgoing connections to the attacker's C2 IP addresses. Every Cisco access switch has its firewall rules updated.	CIO / Network Team	11/02/2026 — 10:00 AM. Firewall rules updated.
Eradication	The standard OilTech Innovations OS image was used to wipe and	Desktop Support Team / Server Team	11/02/2026 — 2:00 PM. Workstation and

	reimagine the compromised researcher's workstation. After wiping it out, the R&D file server was rebuilt from scratch. Before reconnecting, every system was examined and found to be free of malicious code.		server rebuilt and tested clean.
Eradication	The backup taken at 6:00 AM on October 02, 2026, was used to compare data before and after the incident. Files that were encrypted were found. Every encrypted file was recovered from the backup. It was verified that the restored data was complete and unaltered.	Server Team / CIO	11/02/2026 — 4:00 PM. Data restored. Integrity confirmed.
Eradication	Every employee was informed of the status of the system restoration and the eradication's completion. The file server will be back up and running by the end of the day, according to R&D personnel.	Director – Back Office — Syed Ahmed Sameeuddin	11/02/2026 — 4:30 PM. Staff notified.
Eradication	All current clients of OilTech Innovations received a client advisory verifying that the incident had no impact on client data (seismic processing outputs and SensorDrill/MeasureMe operational data). The impacted R&D file	Director – Sales and Product — Syed Ahmed Sameeuddin	12/02/2026 — 9:00 AM. Client advisory issued.

	server did not contain any client data.		
Recovery	In compliance with an emergency patch cycle authorized by the CSO, all outstanding security patches were examined, tested, and installed on all client PCs and servers. For the highest-priority patches, automatic patch testing was expedited.	CIO / Server Team / Desktop Support Team	12/02/2026 — 9:00 AM onward. Emergency patch cycle initiated.
Recovery	Network access restrictions were examined and strengthened. MFA is now required for all remote access. Only authorized devices can access VPNs. Group Policy was used to update and enforce password-complexity requirements.	CIO / Network Team	12/02/2026 — 10:00 AM. Network access hardened.
Recovery	All R&D and server room systems underwent a thorough vulnerability assessment, which focused on unpatched vulnerabilities and improperly configured access controls. A schedule for remediation was created.	CIO / Network Team	12–13/02/2026. Vulnerability assessment completed. Remediation schedule issued.
Recovery	Production was resumed on the R&D file server. Every member of the R&D team attested to the integrity of the data and the restoration of access.	Server Team	12/02/2026 — 5:00 PM. R&D file server restored to production.

Recovery	The complete system recovery was communicated to every employee. Guidelines for spotting phishing emails and reporting questionable communications were released in a security bulletin.	Director – Back Office — Syed Ahmed Sameeuddin / Desktop Support Team	12/02/2026 — 5:30 PM. Staff notified. Security bulletin distributed.
Recovery	The OilTech Innovations website released a public statement confirming that the incident had been contained and resolved, that no client data had been impacted, and detailing the security measures implemented.	Director – Sales and Product — Syed Ahmed Sameeuddin	13/02/2026 — 9:00 AM. Public statement published.
Lessons Learned	The CSO and CIO examined all forensic evidence gathered during the incident, including audit logs, forensic photos, network traffic captures, memory dumps, and IoC reports.	CSO — Asis Hang Rai / CIO — Bibek Chaudhary Tharu	16/02/2026. Forensic review completed.
Lessons Learned	The incident cost was estimated at 18 hours of overtime for IT personnel, 1 day of lost productivity in R&D, emergency patching costs, and subscription fees for external threat intelligence. The estimated total cost is AUD \$45,000. There was no ransom paid. There was no impact on client data. There were no fines from the authorities.	CSO / Director – Back Office — Syed Ahmed Sameeuddin	16/02/2026. Cost assessment completed.

Lessons Learned	The incident's timeline, root cause (spear phishing leading to credential theft), systems impacted, data impact (none—restored from backup), containment and eradication actions, and lessons learned were documented in an Executive Summary, which was created and given to the CEO.	CSO — Asis Hang Rai	17/02/2026. Executive Summary presented to the CEO.
Lessons Learned	Together with the Legal Officer, the CSO went over the NDB scheme obligations. It was concluded that a formal NDB notification to the OAIC was not necessary for this incident because no client personal information was compromised and no significant harm was anticipated. The decision was recorded.	Legal Officer — Bibek Chaudhary Tharu / CSO	17/02/2026. NDB determination documented.
Lessons Learned	All employees were required to complete additional security awareness training focused on identifying spear-phishing emails, avoiding clicking links in unexpected emails, and reporting suspicious communications. Two weeks after the incident, a targeted phishing simulation was carried out.	Director – Back Office — Syed Ahmed Sameeuddin / Desktop Support Team	24/02/2026. Training completed. Phishing simulation conducted.

Lessons Learned	Improved email filtering requirements, mandatory MFA for all remote access as a baseline control (not just post-incident), and detailed instructions for managing spear-phishing-related incidents were all added to the IRP.	CSO / Legal Officer — Bibek Chaudhary Tharu	28/02/2026. IRP updated to v1.1.
Lessons Learned	Lessons learned, the revised security requirements, and the new phishing reporting process were communicated to every employee.	Director – Back Office — Syed Ahmed Sameeuddin	28/02/2026. Organization-wide notification issued.
Lessons Learned	Big Lake ISP and pertinent vendors received a post-incident summary confirming the incident had been resolved and requesting confirmation that no unusual traffic from OilTech Innovations' network had been found on their infrastructure.	CIO — Bibek Chaudhary Tharu	28/02/2026. Vendor communications completed.

End of OilTech Innovations Security Master Plan and Incident Response Plan Document Version 1.0 - Prepared by Asis Hang Rai, Syed Ahmed Sameeuddin, and Bibek Chaudhary Tharu - ICT280, 2026

ICT280 Group Declaration Sheet

Assignment title: Security Master Plan

Group Name (Workshop No. – Group No.): OilTech Innovations (Workshop 2- Group 11)

Member's Names	Brief Description of Tasks	Member's contribution to the total work (%)	Date signed	Signature
Asis Hang Rai	As CEO and CSO, authored Section 1 (Introduction) covering company overview, products and services, market position, R&D projects, organisational hierarchy, purpose of the SMP, and key concepts. Led the Risk Assessment (Section 3) including security management best practices, asset inventory, asset classification and valuation, asset ranking, vulnerability assessment, and the TVA worksheet (current state and proposed). Authored the Incident Response Plan (Appendix), serving as Policy Owner, Incident Commander, and Incident Response Team Lead. Coordinated overall document structure, formatting, and review.	33.3	04/04/2025	Asis Hang Rai

Syed Ahmed Sameeuddin	As Director of Back Office and Director of Sales & Product, authored the Administrative and Back Office unit analysis across Sections 2a, 2b, 2c, and 2d, covering technical, physical, human, and procedural threats and countermeasures relevant to finance, HR, and sales systems. Contributed to Section 4 (Risk Management) for the Administrative Business Unit, including credential compromise mitigation and third-party vendor transference strategies. In the Incident Response Plan, served as HR communications lead and external communications lead, handling staff notifications, client advisories, and the public statement.	33.3	04/04/2025	Syed Ahmed Sameeuddin
Bibek Chaudhary Tharu	As CIO and Legal Officer, authored the IT infrastructure and data centre analysis in Sections 2a and 2b, and led the Legal and Compliance threat analysis across Sections 2c and 2d, including document retention risks and privacy breach procedures. Contributed to Section 4 (Risk Management) for the Legal and Compliance Business Unit, covering document disposal avoidance and acceptance strategies. Authored the References section (Section 5). In the Incident Response Plan, served as Technical Response Lead (CIO) overseeing network, server, and desktop teams, and as Legal Officer managing NDB scheme compliance determinations and IRP updates.	33.3	04/04/2025	Bibek Chaudhary Tharu

Total percentage <i>(should total to 100% if all work is completed)</i>		100%		
---	--	------	--	--